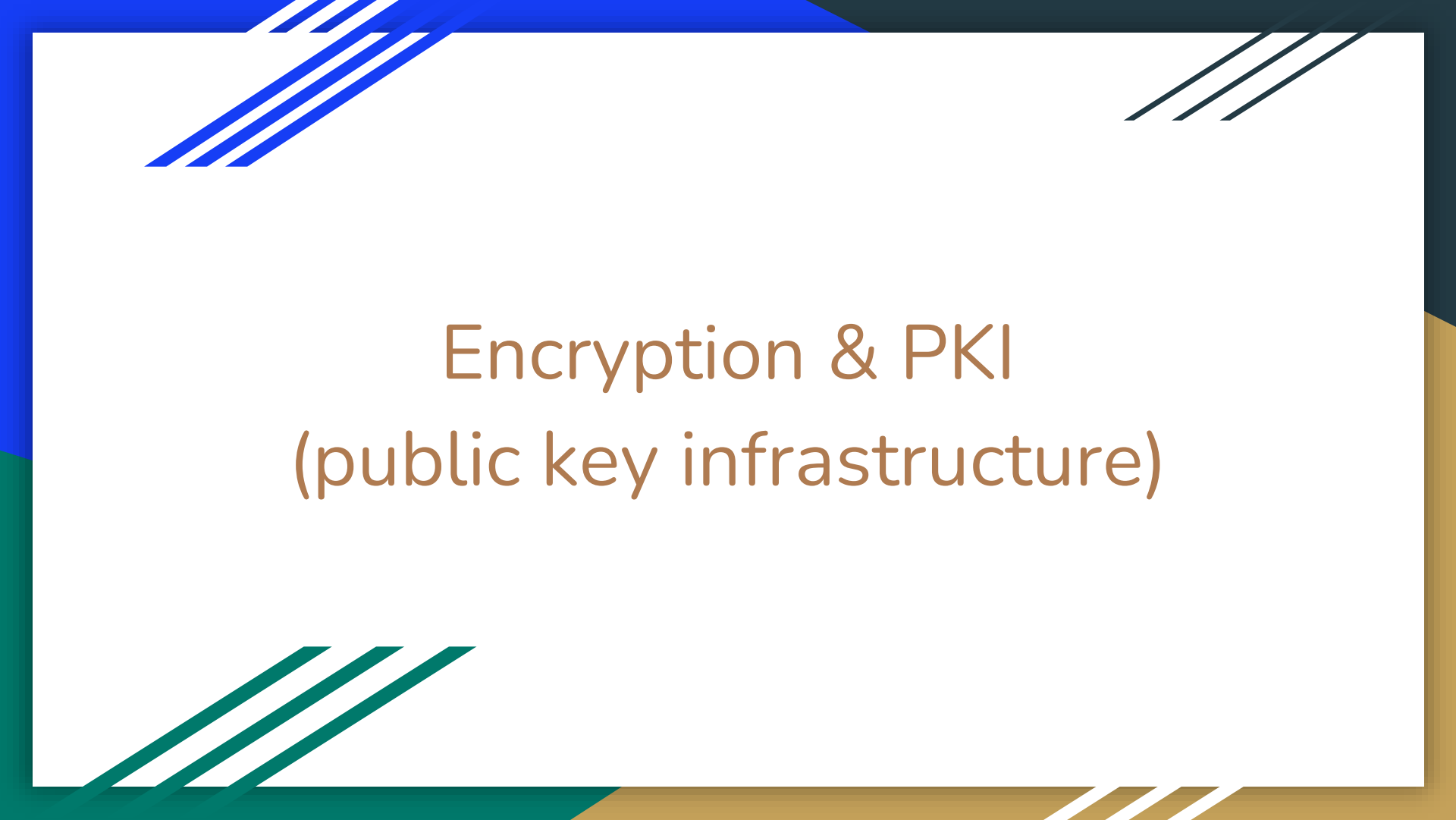




Encryption & PKI

(public key infrastructure)

Encryption

Encryption ensures that data cannot be processed without an encryption key. Decryption can occur at different points of transit.

In Flight (SSL) — data is encrypted before being sent and decrypted by the receiver. SSL cert help prevent man in the middle attacks.

Server Side Encryption — Data is encrypted after being received and decrypted before being sent.

Client Side Encryption — data encrypted by client and decrypted by the receiver.

Encryption Keys — encrypt and decrypt data sent between network endpoints (for instance a client service requesting information from database). Data passed between these endpoints would not be readable until it is decrypted using the encryption key.

PKI definition

Public key infrastructure (PKI) is a catch-all term for everything used to establish and manage public key encryption, one of the most common forms of internet encryption. It is baked into every web browser in use today to secure traffic across the public internet, but organizations can also deploy it to secure their internal communications and access to connected devices.

The most crucial concept involved in PKI is, as its name implies, the public cryptographic keys that are at its core. These keys not only are part of the encryption process, but they help authenticate the identity of the communicating parties or devices.

How does PKI work?

The most important concepts to understand to grasp how PKI works are keys and certificates. A key, as already noted, is a long string of bits — a number, in other words — that's used to encrypt data. For instance, if you used the ancient and simple Caesar cipher with a cryptographic key of 3, that would mean that every letter in your message is replaced by one three letters later in the alphabet — A becomes D, B becomes E, and so forth. To decode its message, your recipient would need know not only that you were using the Caesar cipher but that your key was 3.

Obviously the mathematics behind modern encryption is much more complicated than this. One of the ways it's different gets around a somewhat obvious problem with the Caesar cipher: you have to somehow let your recipient know the key used to encode the encrypted message.

How does PKI work?

PKI gets its name because each participant in a secured communications channel has two keys. There's a public key, which you can tell to anyone who asks and is used to encode a message sent to you, and a private key, which you keep secret and use to decrypt the message when you receive it. The two keys are related by a complex mathematical formula that would be difficult to derive from brute force.

So that covers how data is encrypted within a public key infrastructure. But remember, PKI is widely used because, in addition to encrypting messages, it also lets you know that the person with whom you're exchanging encrypted messages is who they say they are. That's where certificates come in.

What are PKI certificates?

PKI certificates are documents that act as digital passports, assigned to any entity that wants to participate in a PKI-secured conversation. They can include quite a bit of data. One of the most important pieces of information a certificate includes is the entity's public key: the certificate is the mechanism by which that key is shared. But there's also the authentication piece. A certificate includes an attestation from a trusted source that the entity is who they claim to be. That trusted source is generally known as a **certificate authority (CA)**.

What are PKI certificates?

With these concepts under our belt, these are the elements that go into PKI.

- A **certificate authority**, which issues digital certificates, signs them with its own public key, and stores them for reference.
- A **registration authority**, which verifies the identities of those requesting digital certificates. A CA can act as its own registration authority or can use a third party to do so.
- A **certificate database** that stores both the certificates and metadata about them—most importantly, the period of time for which the certificate is valid.
- A **certificate policy** outlining the PKI's procedures, which allows outsiders to judge how trustworthy the PKI is.

How to get a PKI certificate

From the description of those components, you can see that trust is at the center of any PKI infrastructure. One of the things I'm doing when I send you my digital certificate is trying to get you to trust that I am who I say I am—and the certificate helps by having a trusted third party vouch for me.

To understand how that works in practice, let's consider for a moment the most widespread public key infrastructure system out there: the TLS/SSL protocol, which secures just about all encrypted HTTP communication.

To offer TLS-encrypted communication, the owner of a website needs to obtain a certificate from a certificate authority, as we've already discussed. There are a wide range of vendors who've set themselves up as CAs, and before they issue one to you, they require that you prove your ownership of your website in some way. For instance, if you're trying to buy an SSL certificate for a website at `example.com`, you may need to send the CA an email from `hostmaster@example.com`, which is an address that would be restricted to someone with management authority over that domain name. Once you acquire the certificate, you can upload it to your web server.

How to get a PKI certificate

The next obvious question, of course, is how you know you can trust the CA: after all, in the case of TLS, there's no centralized body in charge of the standard and anyone can set themselves up as a certificate authority. A bad actor in that role could wreak havoc. In practice, OS and browser makers like Apple, Microsoft, and Mozilla are the de facto gatekeepers here, maintaining lists of trusted CAs and blacklisting those who slip. The decisions on which CAs to trust have high stakes, as a 2017 showdown between Google and Symantec over what Google felt were Symantec's lax standards made clear.

How to get a PKI certificate

An SSL certificate is probably the most common type of PKI certificate you would encounter in the wild. But as we'll discuss in a moment, it isn't the only kind. Other PKIs will have different standards for issuing certificates, but the important thing to keep in mind is that any PKI system must have some method by which CAs can authenticate users, and that all participants in the PKI system trust that method. SSL/TLS uses what's called a chain of trust, in which users eventually must choose to trust a root certificate-granting authority; an alternate scheme, outlined by Finjan Cybersecurity, is the web of trust, in which users' certificates are signed by other users. A web of trust system is better suited to self-contained networks or organizations, or small communities of users.

What is PKI used for?

SSL may be the most widespread implementation of PKI, but it certainly isn't the only one. This Experts Exchange thread has a great list of real-world PKI applications, including:

- Providing a recovery key for an encrypted hard drive
- Securing internal communications with database servers
- Signing documents
- Securing local networks — PKI capacities are built into Microsoft's Active Directory, for instance, and can work with physical keycards that store digital certificates to ensure that users are who they say they are.
- Secure messaging — The Signal protocol uses PKI, for instance
- Email encryption
- Securing access to internet of things (IoT) devices

Why do we need PKI for secure email?

PKI is great for securing email for the same reason that it's great for securing web traffic: because data flowing over the open internet can be easily intercepted and read if it isn't encrypted, and because it can be difficult to trust that a sender is who they claim to be if there isn't some way to authenticate their identity. As we've seen, establishing near-universal PKI for web traffic has been relatively easy because most of the necessary infrastructure is built into web browsers and servers. Email is accessed through more heterogeneous clients, which makes things a bit trickier.

One of the oldest and best-established PKI systems for securing email is S/MIME; there's also PGP (Pretty Good Privacy), which uses the web of trust model we discussed above. Support for these kinds of email protections are built into clients like Microsoft Outlook. The rise of web-based email in recent years has seen a step backwards in this regard. Gmail, for instance, only supports S/MIME in paid G Suite accounts, not free accounts.

What are the risks of poor PKI execution?

Having PKI in place does not guarantee security. Companies sometimes fail to deploy or manage it properly. A recent study by the Ponemon Institute surveyed nearly 17,000 IT and security practitioners about their key and certificate management practices. The report identified the most significant risks associated with securing digital identities using PKI:

Downtime and outages due to mismanaged digital certificates is rising, with 73% of respondents reporting certificate-related incidents. Fifty-five percent said their organizations had experience four or more incidents in the past two years.

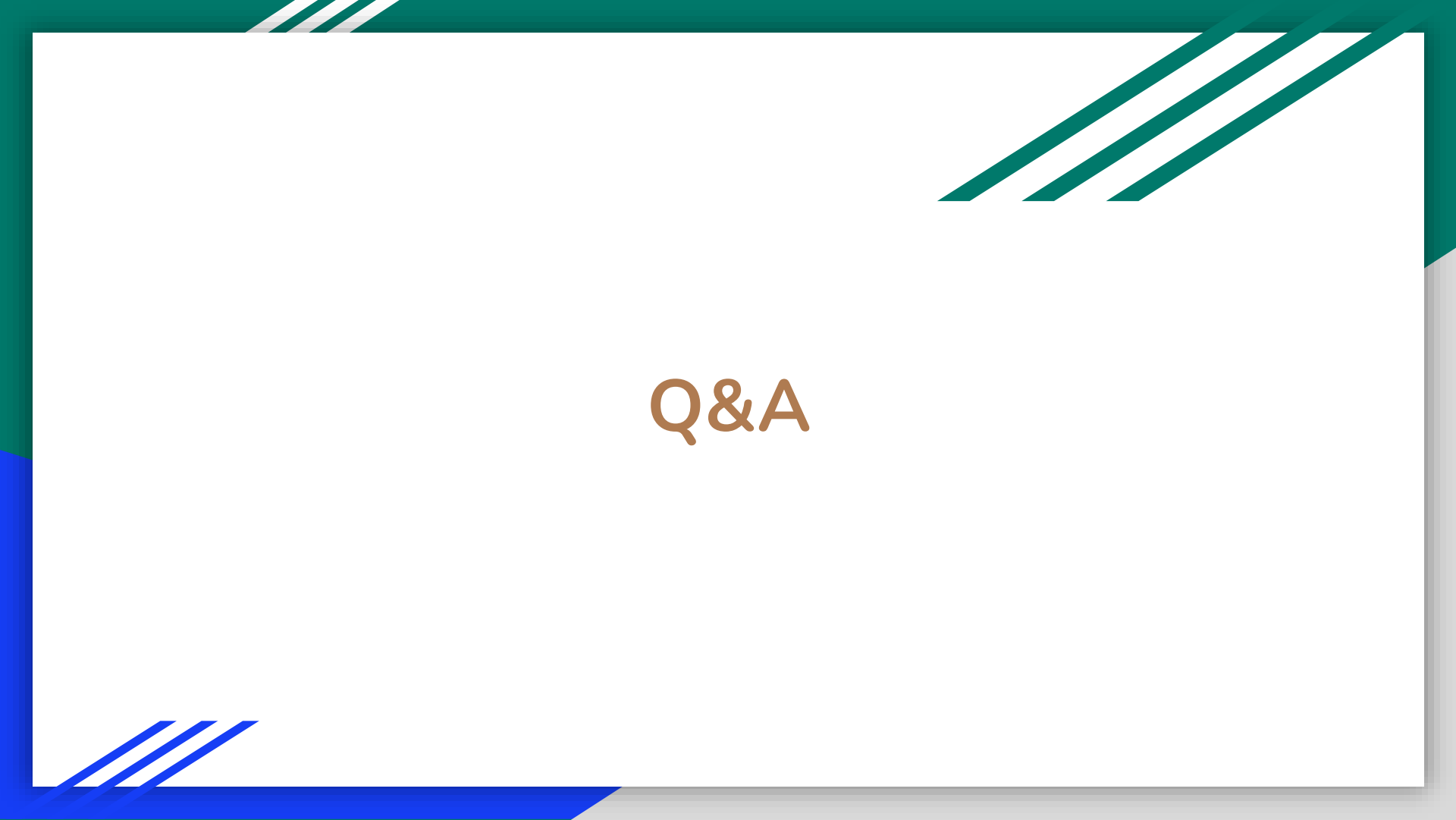
Unsecured digital identities undermine trust. Organizations use an average of 88,750 keys and certificates, but only 74% of respondents said they knew the exact number or when they all expire and 76% said that failure to secure keys and certificates would undermine the trust their organizations need to operate. Fifty-nine percent of respondents say cybercriminals misusing keys and certificates increases the need to secure them.

What are the risks of poor PKI execution?

Failed audits and CA compromise are the biggest threats. Attackers can use compromised or rogue CAs to deliver malware to conduct man-in-the-middle or phishing attacks. Security or compliance audits might fail to detect vulnerabilities due to unenforced key management policies or inadequate key management practices.

More encryption increases operational complexity and cost. Two-thirds of respondents are adding layers of encryption to meet regulatory and IT policy requirements. For example, 60% say they are adding encryption layers to secure IoT devices. That can diminish the overall efficiency of business processes, say 64% of respondents, and 58% say management of more keys and digital certificates is increasing cost.

Most organizations lack resources to support PKI or do not assign clear ownership of it. Only 38% of respondents said they have the IT staff to properly support PKI. Responsibility for PKI, budget-wise, is often spread across the organization with IT operations (21%) and lines of business (19%) the most common owners. Thirteen percent said responsibility was shared with no single owner. Respondents spent about 16% of their security budget on PKI, or \$3 million on average.



Q&A